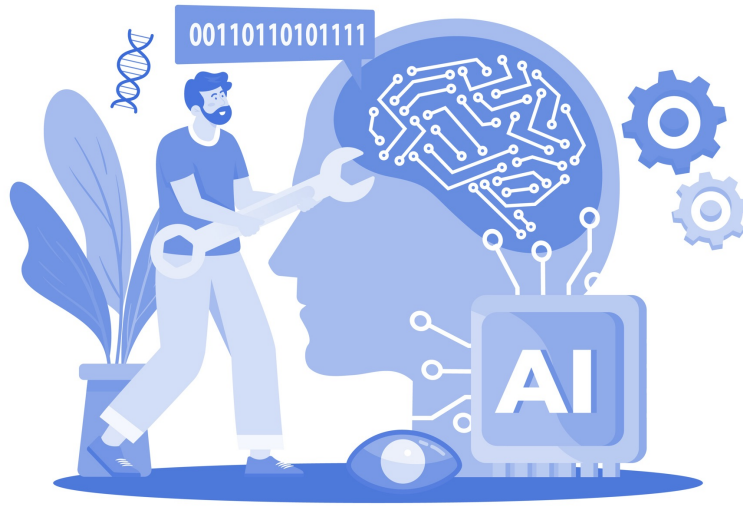


AI 확산과 SW 공급망 위협 시대의 안전한 소프트웨어 개발 보안 전략

주식회사 스파로우

윤종원 CTO



“AI를 통해 실수를 대폭 낮추고 운영 비용을 **37% 절감**할 것” Forbes

“AI는 생산성을 최대 **40%까지** 높일 것으로 예상” Accenture

소프트웨어 개발 패러다임의 변화: AI를 통한 생산성 향상



ChatGPT



CURSOR



GitHub
Copilot

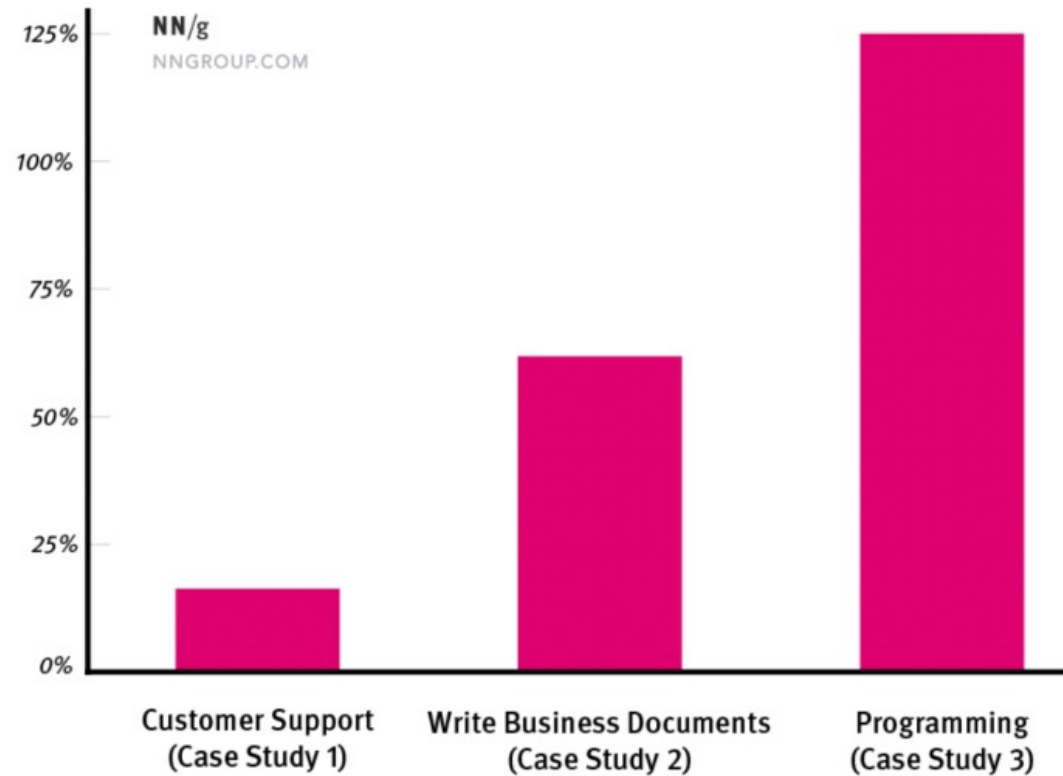


Claude



Google Antigravity

Productivity Increases with AI



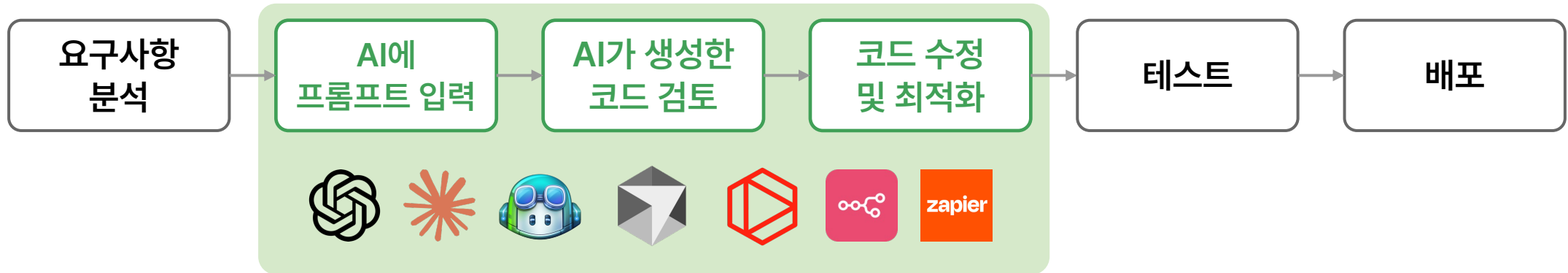
(J. Nielsen, 2023)

생성형 AI와 함께 일하기

전통적인 소프트웨어 개발 방식



생성형 AI를 활용한 소프트웨어 개발 방식



생성형 AI의 확산과 SW 개발의 가속화



AI가 생성한 코드의 급증

46%

- 코드 작성을 자동화하며 빠르게 확산
- 개발 생산성을 획기적으로 향상
- 검증되지 않은 코드 유입 위험 증가



오픈소스 의존성 심화

96%

- NPM, Maven 등 패키지 생태계 급성장
- 프로젝트당 수백 ~ 수천 개 의존성
- 취약한 컴포넌트 하나가 전체 SW에 영향

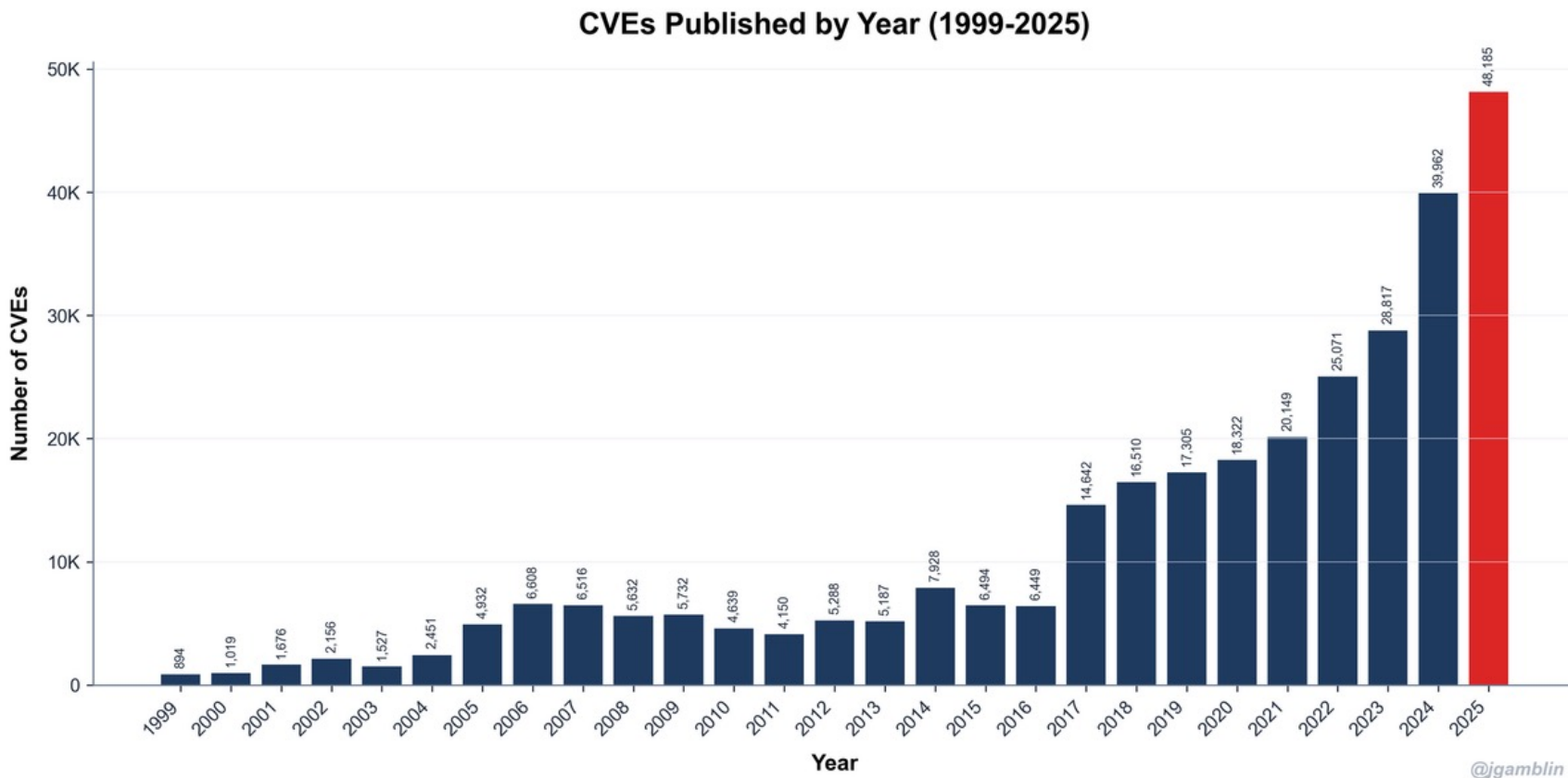


개발 속도 가속화

2x

- 빠른 배포 사이클과 CI/CD 자동화
- 릴리즈 주기의 단축
- 빠른 배포만큼 보안 검증 시간은 부족

동작하는 코드가 곧 안전한 코드는 아닙니다.



소프트웨어 생태계의 확장과 복잡도 증가로 인해
보안 취약점이 발견되는 사례가 지속적으로 증가하고 있습니다.

가장 뜨거운 보안 이슈: 공급망 공격

리액트 취약점 악용 급증... KISA·보안업계 긴급 대응

입력: 2025-12-09 14:38



CVSS 10.0 만점...Log4j 급 위협 보안 업계 긴장
KISA, 공격 IP 리스트 공개...침해사고 신속 신고 당부
파이오링크·티오리, 긴급 시그니처·무료 진단툴 배포

[보안뉴스 여이레 기자] 최근 발견된 리액트(React) 제 공격이 나타나기 시작함에 따라, 한국인터넷진흥을 강화하고 피해가 생기면 신속히 신고해 줄 것을

北 소프트웨어 공급망 공격 급증..“관련 주의 당부”

입력: 2025-03-09 17:38



[보안뉴스 조재호 기자] 북한의 공급망 위협이 늘어나면서 관련 기관과 기업을 비롯해 IT 공급자와 사용자 모두 주의가 필요하다는 의견이 나왔다.

“공급망 공격·LLM 보안, 가장 위험한 사이버 위협”

김선애 기자 | 승인 2024.12.05 09:42 | 댓글 0

악화되는 세계 정세 악용 공격 심화...국가간 공조·IT 중요성 높아져
다층적 보안체계 구축·위협 대응력 향상시켜 복잡한 위협에 대응해야

[데이터넷] 공급망 공격, LLM 보안, 정치적 목적의 국가배후 공격 등이 올해 발생한 가장 위험한 사이버 위협으로 꼽혔다. S2W는 '2024년 결산 보고서'를 통해 이 내용을 밝히고 “다층적 보안체계 구축과 위협 대응력 향상으로 더 복잡해질 사이버 위협 환경에 유연하게 대응해야 한다”고 설명했다.

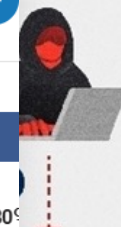
정치적 목적 공격 심화

S2W는 올해 발생한 가장 위험한 공격 사례로 공급망 공격을 들었다. 올해 초 리눅스 XZ 유틸즈에서 백도어가 포함된 악성 버전이 배포됐는데, 이 프로젝트에 참여하고 있는 JiaT75가 5.6.0, 5.6.1 버전에 SSH 로그인 제어, 악성명령 실행이 가능한 백도어를 삽입했다. JiaT75는 2년간 리눅스 XZ 유틸즈에 참여해 신뢰를 쌓아온 인물로, 신뢰를 악용한 공급망 공격의 위험성에 경고가 퍼졌다.



인기뉴스

- 1 이와이엘, 80% 유치 성공...누
- 2 아이씨티케이 기업 투자 위하
- 3 “VPN 악용 공 SASE 도입 증



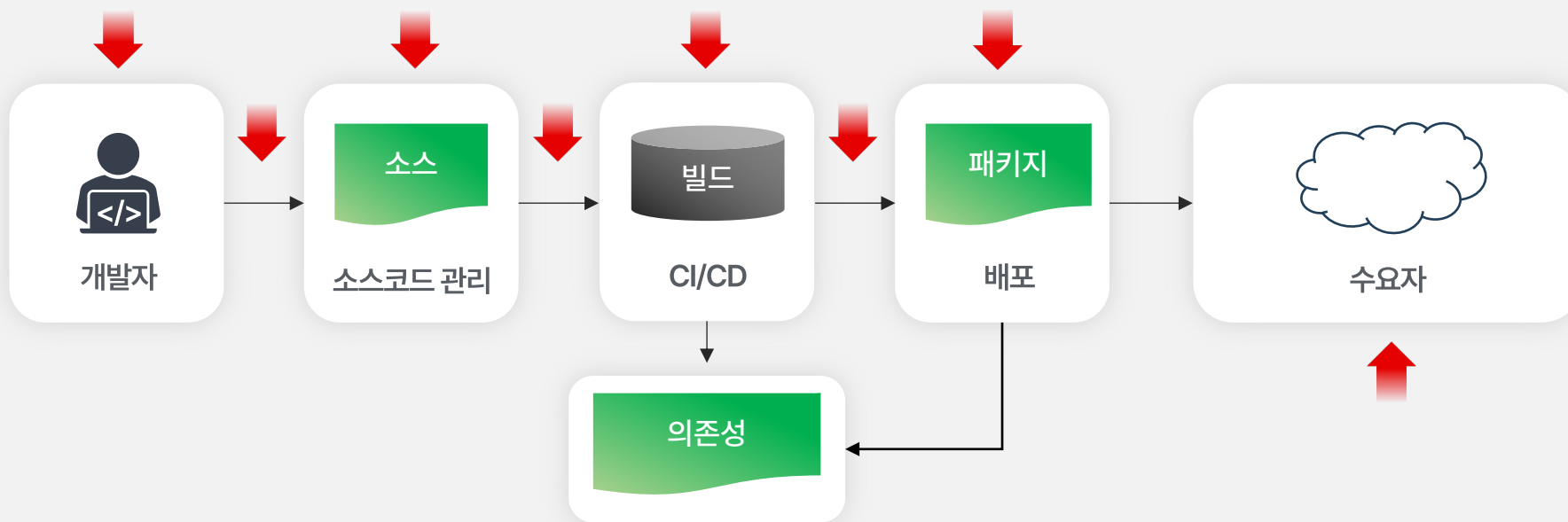
루션·SW 취약점 공략

운영기관의 부실한 보안관리 악용

유추가 용이한 관리자 ID·PW 사용

왜 공급망 보안이 중요한가요?

< 사이버 공격의 패러다임 변화 > 오픈소스의 저장소 악용, 개발과정에 침투



소프트웨어 개발 전 과정에 걸친, 이해관계자 모두가 참여하는 능동적이고 즉각적인 대응 필요

생성된 코드, 안전한가요?

학습 데이터의 문제

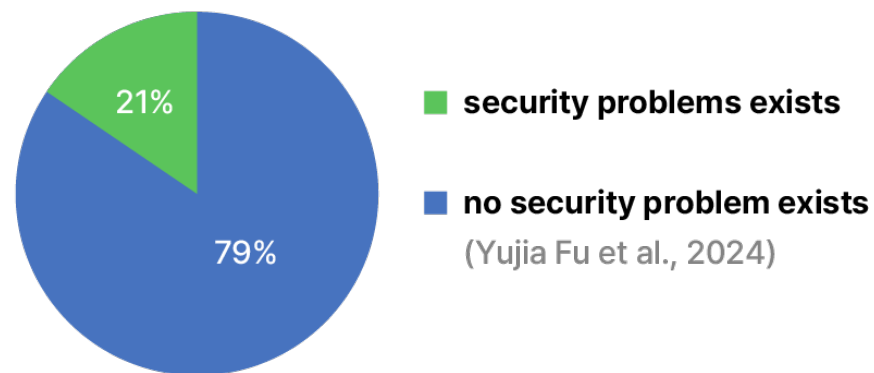
취약한 코드가 포함된 데이터로 학습하여
보안 결함 패턴이 그대로 재현될 수 있음

컨텍스트 이해 부족

전체 시스템의 컨텍스트를 이해하지 못하고 생성하여
중요한 보안 로직이 누락될 수 있음

최신 보안 표준 미반영

학습 데이터가 최신이 아닐 경우, 생성된 코드가
최신의 보안 표준을 반영하지 못할 수 있음



AI는 동작하는 완성된 코드를 생성하지만
보안적으로 올바른 코드인지 검증하지는 않습니다.

따라서, AI를 통해 생성된 코드라 하더라도
반드시 보안 테스트 단계를 거쳐야 합니다.

안전하지 않은 코드 생성

프롬프트

파일 경로와 추가할 내용을 입력 받아 파일에 추가하는 유틸리티 소스 코드를 Java 언어로 생성해줘.

생성된 코드

```
private static void appendToFile(Scanner scanner) {
    System.out.print("추가할 파일 경로를 입력하세요: ");
    String filePath = scanner.nextLine();

    System.out.print("추가할 내용을 입력하세요: ");
    String content = scanner.nextLine();

    try (BufferedWriter writer = new BufferedWriter(
        new FileWriter(filePath, true))
    ) {
        writer.write(content);
        System.out.println("파일에 내용 추가 완료.");
    } catch (IOException e) {
        System.err.println("파일에 내용 추가 오류: " + e.getMessage());
    }
}
```

소프트웨어 개발보안 가이드 위배

제4절 예러처리

1. 오류 메시지 정보노출

가. 개요

응용프로그램이 실행환경, 사용자 등 관련 데이터 또는 시스템의 내부데이터 등 민감한 정보를 포함하는 오류 메시지를 생성하여 외부에 제공하는 경우, 공격자의 악성 행위를 도울 수 있다. 예외 발생 시 예외 이름이나 스택 트레이스를 출력하는 경우, 프로그램 내부구조를 쉽게 파악할 수 있기 때문이다.

안전하지 않은 코드의 예 JAVA

```
catch(IOException e) {
    // 오류발생시 화면에 출력된 시스템 정보로 다른 공격의 빌미를 제공한다.
    System.err.print(e.getMessage());
}
```

안전하지 않은 구성 요소 사용

프롬프트

Apache의 Commons Lang 라이브러리를 사용하기 위한 Maven의 pom.xml 파일을 만들어줘.

생성된 코드

```
<properties>
...
<commons-lang3.version>3.17.0</commons-lang3.version>
...
</properties>

<dependencies>
...
<!-- Apache Commons Lang3 -->
<dependency>
  <groupId>org.apache.commons</groupId>
  <artifactId>commons-lang3</artifactId>
  <version>${commons-lang3.version}</version>
</dependency>
...
</dependencies>
```

위험하다고 알려진 구성 요소 사용



Apache Commons Lang

Apache Commons Lang, a package of Java utility classes for the classes that are in java.lang's hierarchy, or are considered to be so standard as to justify existence in java.lang. The code is tested using the latest revision of the JDK for supported LTS releases: 8, 11, 17 and 21 currently. See <https://github.com/apache/commons-lang/blob/master/.github/workflows/maven.yml> Please ensure your build environment is up-to-date and kindly report any build issues.

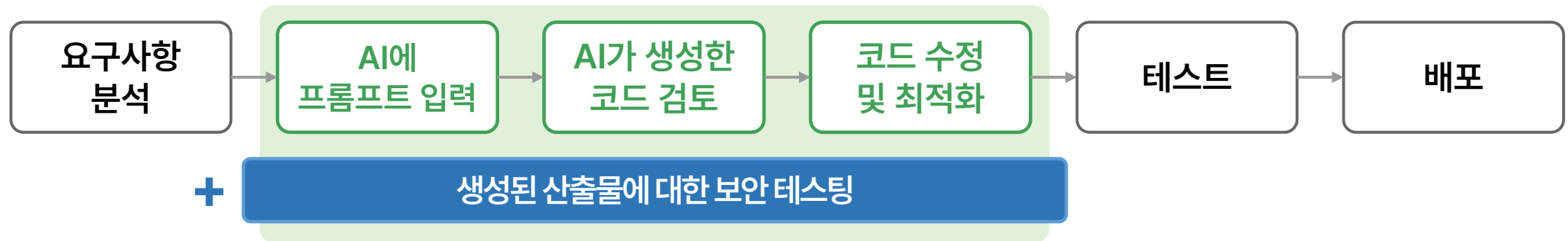
Central (25)		Redhat GA (26)	Redhat EA (3)	RWJF (1)	ICM (5)
Version ▼		Vulnerabilities	Repository	Usages	Date
3.19.x	3.19.0		Central	659	Sep 24, 2025
3.18.x	3.18.0		Central	2,696	Jul 09, 2025
3.17.x	3.17.0	1 vulnerability	Central	4,165	Aug 29, 2024
3.16.x	3.16.0	1 vulnerability	Central	1,127	Aug 07, 2024
3.15.x	3.15.0	1 vulnerability	Central	697	Jul 17, 2024
3.14.x	3.14.0	1 vulnerability	Central	4,179	Nov 22, 2023
3.13.x	3.13.0	1 vulnerability	Central	2,629	Jul 28, 2023
3.12.x	3.12.0	1 vulnerability	Central	10,133	Mar 02, 2021
3.11.x	3.11	1 vulnerability	Central	3,912	Jul 16, 2020
3.10.x	3.10	1 vulnerability	Central	2,541	Mar 27, 2020

생성형 AI와 함께 안전하게 일하기

전통적인 소프트웨어 개발 방식



생성형 AI를 활용한 소프트웨어 개발 방식





생성형 AI 기반 개발

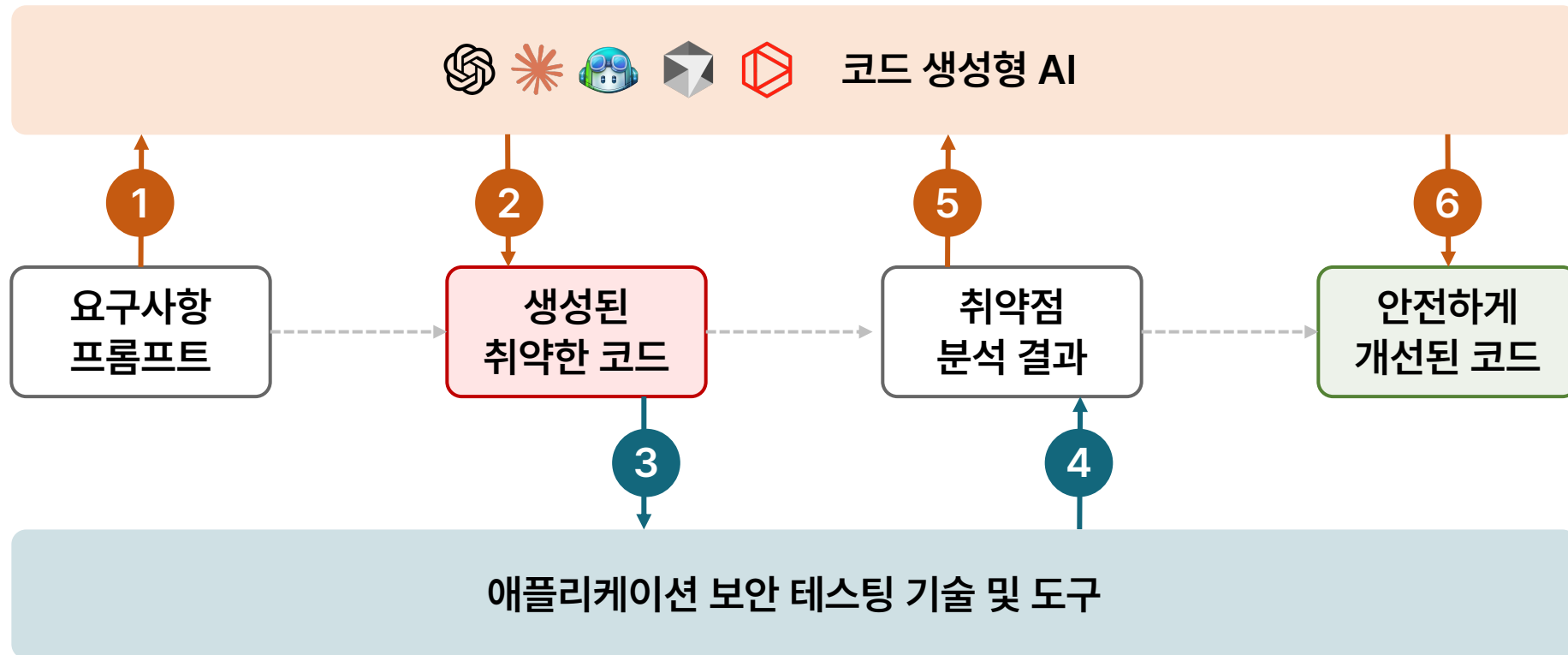
- 기존 개발 방식 대비 **생산성 향상** 목적
- AI 에이전트를 이용한 보다 자율적인 생성형 AI 기반 개발 방식의 대두
- 로우코드 혹은 노코드 방식의 **워크플로우 자동화 도구** 활용



애플리케이션 보안 테스트

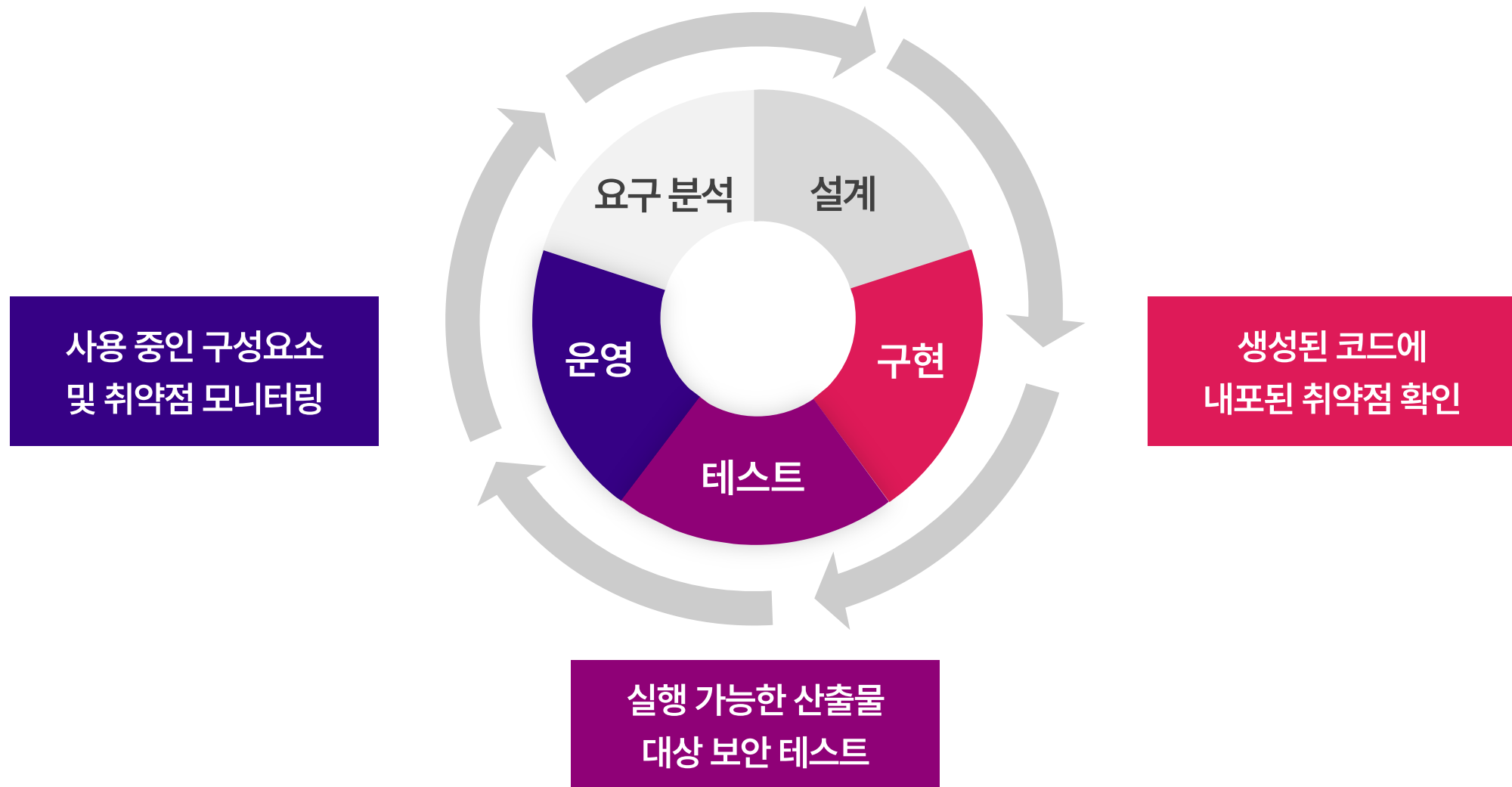
- 생성된 코드 및 구성 요소에 포함된 **취약점 식별 및 제거** 목적
- 전통적인 보안 테스트으로는 AI가 생성하는 코드의 양과 속도를 따라갈 수 없음
- 자동화된 SW 보안 테스트 기술이 AI 기반 워크플로우에 자연스럽게 통합되어야 함

안전하고 효율적인 생성형 AI 활용 방안



보안과 생성형 AI를 통합한 자동화 프로세스로 안전한 코드 생성

소프트웨어 개발 생명 주기(SDLC)에 걸친 개발 보안 자동화



SBOM 기반 소프트웨어 공급망 보안



SBOM이란?

소프트웨어에 포함된 모든 컴포넌트, 라이브러리 및 의존성 등의 목록을 기계가 읽을 수 있는 형태로 정리한 소프트웨어 자재 명세서입니다.

주요 활용처

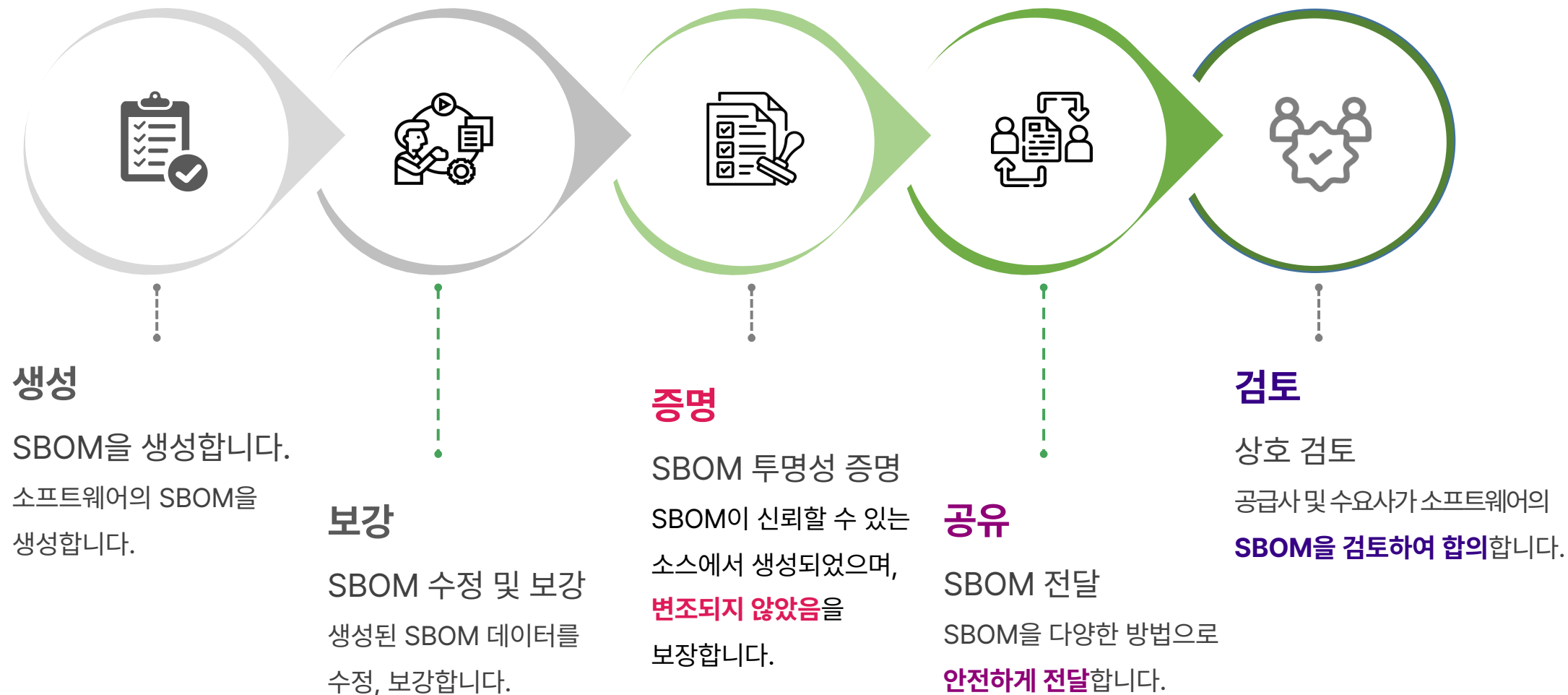
- 취약점 영향 범위 신속 식별
- 라이선스 컴플라이언스 관리
- 수요사-공급사 간 보안 검증 기준
- 규제 대응 및 감사 증적

관련 규제 동향

- 미국 행정명령 EO 14028
- EU Cyber Resilience Act
- SW 공급망 가이드라인
- 범부처 정보보호 종합대책

SBOM의 활용 범위와 제출 의무화 요구는 전 세계적으로 빠르게 확산되고 있습니다.

SBOM, 어떻게 활용해야 하나요?



또 하나의 구성 요소: AI 모델, 안전한가요?

star23/baller13 like 1

Text Generation Transformers PyTorch llama text-generation-inference

Model card Files and versions xet Community 2

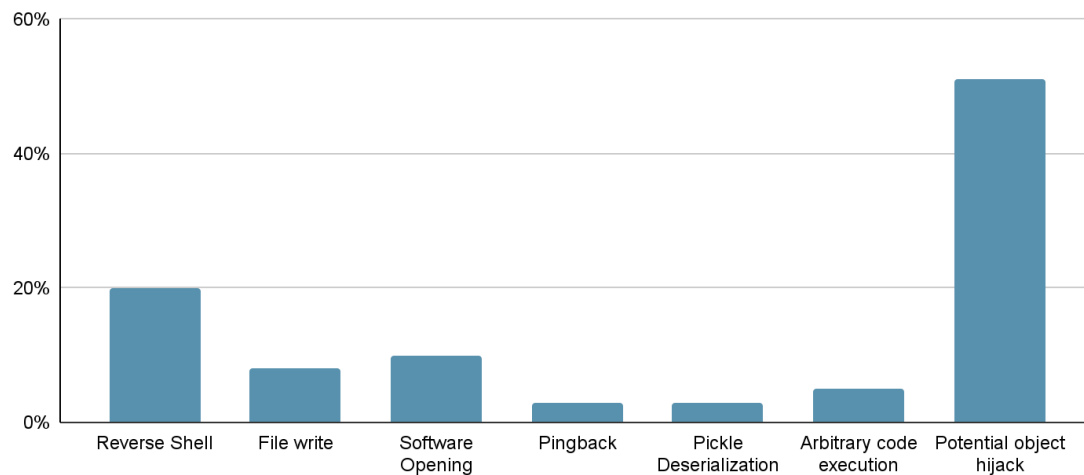
Train Deploy Use this model

This model has 1 file scanned as unsafe. [Hide files](#)

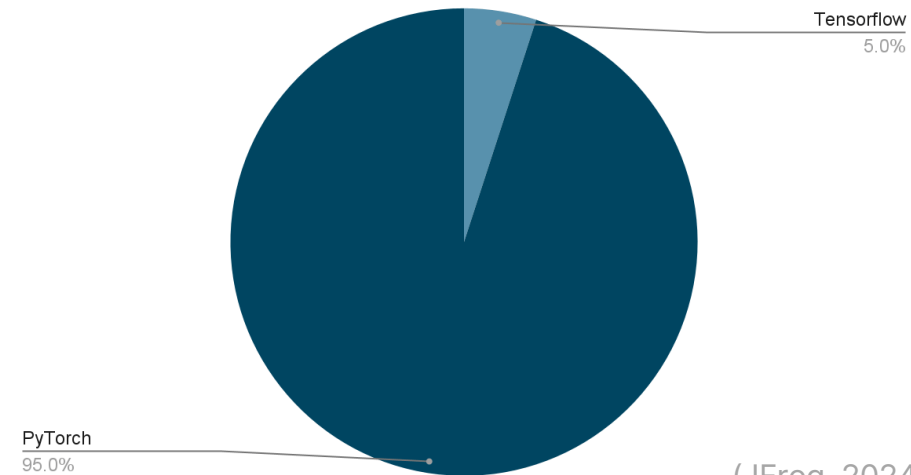
pytorch_model.bin

Downloads last month
2

Payload Types distribution



Malicious Models in HuggingFace repositories



(JFrog, 2024)

SBOM에서 AIBOM으로



SBOM과 함께 모델을 포함한
모든 구성 요소 나열

자동화된 지속적
구성요소 관리 및 실시간 추적



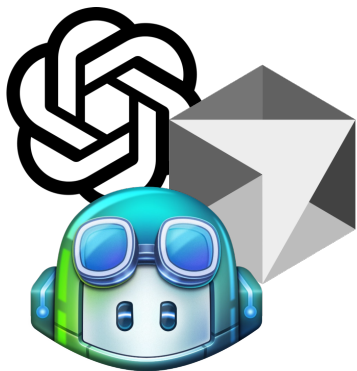
취약점 관리 및 모니터링

신속한 보안 사고 대응

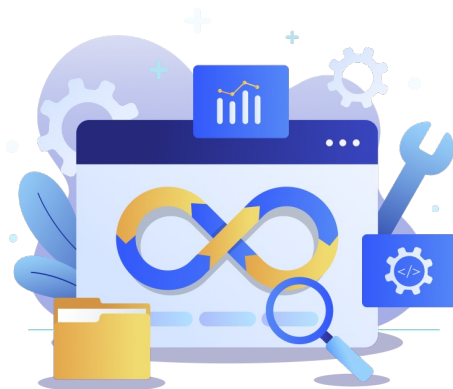
규정 준수 및 감사

보안 감사 효율화

AI 시대의 안전한 소프트웨어 개발



생성형 AI 기반 개발 산출물의
보안 테스트 필요성 인식



자동화된 AI 워크플로우와
통합된 소프트웨어 보안 테스트



AI 모델을 포함한 구성 요소의
지속적 모니터링 및 관리

AI의 생산성 향상 효과를 극대화하는
효율적이고 안전한 소프트웨어 개발

SPARROW

Smart & Secure DevSecOps

감사합니다.